



SAE DROIT

BUT SD 2

Deonna NAICKER - Imane KHARBOUCHE - Quentin CHIROL
- Clara DECROS - H       GUERTIN

Sommaire

Rapport Détaillé de Mise en Conformité au RGPD pour le Service des Ressources Humaines.....	3
I. Désignation d'un Délégué à la Protection des Données (DPD/DPO).....	4
II. Tenue du Registre des Activités de Traitement.....	5
III. Mise en Conformité des Données Traitées (Minimisation et Interdiction)..	6
A) Analyse de Pertinence et Suppression des Données Excessives.....	6
B) Encadrement Strict des Données Sensibles.....	7
C) Rappel sur les droits/devoirs des parties prenantes.....	8
IV. Principe d'une Durée Limitée de Conservation des Données.....	9
V. Obligations d'Information et de Sécurité.....	9
A) Information des Personnes (Transparence).....	9
B) Sécurité, Intégrité et Confidentialité.....	10
VI. Analyse d'Impact relative à la Protection des Données (AIPD).....	11
VII. Synthèse et Plan d'Action Immédiat.....	12
Synthèse Exécutive.....	12
Plan d'Action.....	12

Rapport Détaillé de Mise en Conformité au RGPD pour le Service des Ressources Humaines

Conformément à la demande, ce rapport propose des mesures concrètes et compréhensibles par les dirigeants de votre entreprise industrielle d'une centaine de salariés, afin de sécuriser les traitements de données du service « ressources humaines » et d'assurer la conformité au Règlement Général sur la Protection des Données (RGPD). Le principe du RGPD est de responsabiliser les détenteurs de données personnelles en les obligeant à rapporter la preuve qu'ils ont respecté la loi, sous peine de lourdes sanctions.

Le Règlement Général sur la Protection des Données (RGPD) a été instauré le 25 mai 2018 en Europe, il repose sur cinq principes fondamentaux qui orientent la manière dont les données personnelles doivent être traitées. Ces principes visent à garantir la transparence, la sécurité et le respect des droits des individus en matière de protection de leurs données personnelles.

Les données personnelles ne doivent être collectées que pour des finalités spécifiques, explicites et légales. Elles ne peuvent ensuite être traitées de manière incompatible avec ces objectifs initiaux. Par exemple, si les données sont collectées pour un service particulier (comme une inscription à une newsletter), elles ne doivent pas être utilisées pour une autre finalité, comme du marketing ciblé, sans le consentement explicite de la personne concernée.

Le traitement des données personnelles doit être limité à ce qui est strictement nécessaire au regard des finalités pour lesquelles elles sont collectées. En d'autres termes, seules les données qui sont pertinentes et appropriées pour atteindre l'objectif fixé doivent être collectées. Cela évite la collecte excessive de données et réduit les risques en matière de sécurité et de confidentialité.

Les données personnelles collectées doivent être exactes et, si nécessaire, tenues à jour. Des mesures doivent être prises pour que les données inexactes ou obsolètes soient rectifiées ou supprimées dans les meilleurs délais. Cela permet d'éviter les erreurs et de garantir que les décisions prises sur la base de ces données soient fondées sur des informations fiables.

Les données personnelles ne doivent être conservées que pendant une durée n'excédant pas celle nécessaire aux fins pour lesquelles elles sont traitées. Une fois cette période écoulée, les données doivent être supprimées ou anonymisées. Cela permet de réduire les risques associés à la conservation des données à long terme et d'éviter leur exploitation abusive.

Bien que l'obligation ne concerne pas systématiquement toutes les entreprises de moins de 250 salariés selon le Règlement Général sur la Protection des Données (RGPD), il est fortement recommandé de mettre en place cette mesure dans votre cas, car votre entreprise traite un volume important de données à caractère personnel incluant des informations d'identification complètes (état civil, nationalité, situation familiale, coordonnées), des données relatives à la situation professionnelle et contractuelle, des données sensibles concernant la santé des employés (suivi médical, aptitudes au poste de travail, taux d'invalidité, reconnaissance de la qualité de travailleur handicapé, pathologies), des données syndicales et relatives à l'exercice du droit de grève, ainsi que des données sur la gestion de carrière et les évaluations professionnelles, qui nécessitent toutes un niveau de protection renforcé et une vigilance accrue en matière de conformité et de sécurité des données personnelles.

L'absence de mise en conformité au RGPD depuis 2018 expose votre entreprise à des sanctions sévères. Votre entreprise encourt des amendes pouvant atteindre 20 millions d'euros ou 4% du chiffre d'affaires annuel mondial. La CNIL peut également ordonner une suspension de vos traitements, paralysant ainsi votre gestion des ressources humaines. Sur le plan pénal, vos dirigeants risquent jusqu'à 5 ans d'emprisonnement et 300 000 euros d'amende. Vos salariés peuvent engager des actions en justice pour obtenir réparation, générant des coûts importants. Enfin, cette situation provoquera une grave atteinte à votre réputation et une perte de confiance de vos salariés. Pour éviter ces sanctions l'entreprise peut mettre en place plusieurs mesures :

I. Désignation d'un Délégué à la Protection des Données (DPD/DPO)

Bien que l'obligation ne concerne pas toutes les entreprises de moins de 250 salariés , il est fortement recommandé d'en désigner un car votre entreprise traite des données sensibles (voir Section III).

Recommandations Concrètes :

- Désigner un Délégué à la Protection des Données (DPD), interne ou externe.
- Le DPO sera le « Chef d'orchestre » de la conformité en matière de protection des données au sein de votre organisme.
- Il doit être désigné sur la base de ses connaissances spécialisées du droit et des pratiques en matière de protection des données et ne doit pas avoir de conflit d'intérêt avec ses autres missions.

Conseil :

Afin d'accompagner efficacement la mise en conformité de l'entreprise, il est fortement conseillé de désigner un Délégué à la Protection des Données ou DPO. Ce professionnel aura pour mission principale de veiller à l'application du RGPD au sein de la société. Il devra être en mesure de conseiller la direction et les salariés sur leurs obligations, de superviser la conformité des traitements, de documenter les actions entreprises et d'agir comme point de contact avec la CNIL.

Lors du recrutement d'un DPO, il est recommandé de choisir un profil issu du domaine du droit ou de la gestion des données. Une double compétence en droit de la protection des données et en sécurité des systèmes d'information représente un véritable atout. Si le DPO ne dispose pas encore de toutes les compétences nécessaires, il est essentiel de prévoir dès son entrée en poste des formations certifiantes afin qu'il puisse se former de manière autonome et continue. L'entreprise devra donc anticiper cet accompagnement, en s'assurant que le DPO dispose des moyens nécessaires pour monter en compétence et exercer sa mission de manière indépendante et efficace.

II. Tenue du Registre des Activités de Traitement

Le registre des activités de traitement est un outil de pilotage et de démonstration de la conformité au RGPD. Votre entreprise, étant de moins de 250 salariés, doit tenir un registre pour les traitements suivant:

- Les traitements non occasionnels (ex: gestion de la paie, gestion des clients/prospects).
- Les traitements qui portent sur des données sensibles (ex: données de santé, infractions).

Étant donné que le service RH effectue un traitement non occasionnel (gestion du personnel) et manipule des données sensibles (RQTH, suivi médical, sanctions disciplinaires, appartenance syndicale), la tenue du registre est obligatoire.

Actions Concrètes :

- Créez le Registre des activités de traitement, qui doit se présenter sous une forme écrite (papier ou électronique).
- Pour chaque traitement (ex.: « Gestion de la carrière de l'employé »), la fiche de registre doit comporter au moins les éléments suivants:
 - a. Les finalités du traitement.
 - b. Les catégories de personnes concernées (employé).
 - c. Les catégories de données personnelles.
 - d. Les délais prévus pour l'effacement des données.
 - e. Une description générale des mesures de sécurité techniques et organisationnelles.

III. Mise en Conformité des Données Traitées (Minimisation et Interdiction)

Le traitement des données doit respecter le principe de minimisation des données , signifiant que seules doivent être traitées les informations adéquates, pertinentes et nécessaires au regard des objectifs poursuivis.

A) Analyse de Pertinence et Suppression des Données Excessives

L'organisme doit veiller à ne collecter et n'utiliser que les données pertinentes et strictement nécessaires au regard de ses propres besoins de gestion du personnel. L'information pouvant être demandée à un employé doit présenter un lien direct avec l'appréciation de ses qualités et compétences professionnelles.

Actions Concrètes : Mettez en œuvre le principe de minimisation et supprimez les données non pertinentes.

Donnée Traitée	Catégorie	Non-conformité / Référence	Action à Mener
Nature des études suivies par les enfants	Identification de l'employé	Non pertinente et excessive. Information relative à ses proches.	Supprimer la donnée de tous les supports (numérique et papier) car elle n'est pas nécessaire à la gestion de la carrière ou de la paie. Cette donnée manque de pertinence
Profession des parents de l'employé	Identification de l'employé	Non pertinente et excessive. N'a pas de lien direct avec les qualités professionnelles.	Supprimer la donnée de tous les supports. Le recueil de cette information n'est pas justifié par une finalité précise.
Nombre de jours de grève suivis au cours des 10 dernières années	Suivi de la carrière et de la formation	Non pertinente et excessive. Disproportionné dans le cadre de l'évaluation professionnelle.	Supprimer la donnée de tous les supports. Sa conservation au sein du dossier d'évaluation va au-delà de ce qui est nécessaire

Indication des pathologies des salariés lorsqu'elles sont connues	Suivi administratif des visites médicales	Donnée sensible (Santé). Le traitement est en principe interdit.	Supprimer toutes les notes ou mentions d'indications des pathologies. Ces données doivent rester gérées par les services de médecine du travail
---	---	--	---

B) Encadrement Strict des Données Sensibles

En principe, il est interdit de collecter ou de traiter des données à caractère personnel qui révèlent l'appartenance syndicale, les données concernant la santé ou celles concernant les infractions et condamnations. Le traitement peut être autorisé s'il est nécessaire aux fins de l'exécution des obligations et de l'exercice des droits propres à l'employeur en matière de droit du travail.

Actions Concrètes : Mettez en place des mesures pour les données sensibles traitées :

Donnée Traitée	Catégorie	Base Légale d'Exception	Encadrement Strict
Reconnaissance de la qualité de travailleur handicapé (RQTH)	Donnée de santé	Nécessaire en droit du travail (obligation d'emploi, adaptation).	Traitement limité aux personnes habilitées, pour les finalités d'obligations légales et d'aménagement de poste.
Appartenance syndicale du salarié lorsqu'elle est connue	Appartenance syndicale	Nécessaire en droit du travail (gestion des mandats/délégations)	Ne pas la collecter dans le cadre de l'évaluation professionnelle. Assurer un accès restreint.
Sanctions disciplinaires	Données relatives aux infractions	Intérêt légitime / Exécution du contrat.	Exclure celles consécutives à des faits amnistiés. Conserver selon la durée nécessaire au suivi de carrière.

C) Rappel sur les droits/devoirs des parties prenantes

Dans le contexte actuel où la protection des données personnelles est devenue une priorité majeure, il est essentiel pour toute entreprise, y compris industrielle comme la vôtre, de se conformer au Règlement Général sur la Protection des Données (RGPD). Ce règlement encadre strictement les traitements des données personnelles et impose des obligations claires tant pour les employeurs que pour les salariés. Le service des ressources humaines, qui gère un volume important d'informations sensibles telles que les documents d'identité, les contrats de travail, les données familiales et médicales, doit impérativement mettre en place des mesures adaptées afin de sécuriser ces traitements. Ce rappel des droits et devoirs des différentes parties prenantes vise à clarifier les responsabilités en matière de gestion des données personnelles et à préparer la société à adopter les pratiques conformes au RGPD.

Le processus de recrutement et d'intégration inclut la vérification des documents d'identité tels que le passeport et la nationalité ainsi que la validation des permis de travail pour les employés étrangers. Il est également nécessaire de collecter les coordonnées personnelles et professionnelles des candidats tout en analysant leur situation familiale afin de gérer au mieux les avantages sociaux auxquels ils peuvent prétendre.

La gestion administrative du personnel comprend la mise à jour régulière des dossiers personnels notamment l'état civil et les coordonnées. La gestion des contrats de travail porte sur le type de contrat, la date d'entrée et la nature de celui-ci. Il est aussi important d'assurer le suivi des titres autorisant le travail à travers la collecte des copies des documents ainsi que la gestion des données relatives à l'ancienneté, l'emploi et au coefficient hiérarchique.

Dans le cadre de la gestion de la paie et des avantages sociaux, il convient de prendre en compte les enfants à charge pour le calcul des allocations. De plus, la gestion des situations familiales et matrimoniales est essentielle pour l'application des avantages fiscaux. Les informations concernant le taux d'invalidité ainsi que la reconnaissance de la qualité de travailleur handicapé (RQTH) doivent être traitées pour permettre les aménagements nécessaires ou les exonérations.

La gestion des absences et de la santé au travail nécessite un suivi attentif des taux d'invalidité et de la reconnaissance de handicap (RQTH) ainsi qu'une adaptation des conditions de travail en fonction des besoins spécifiques. La coordination avec le médecin du travail est primordiale. De plus, il faut prévoir la gestion des situations d'urgence en utilisant notamment les coordonnées des personnes à prévenir en cas de besoin.

En ce qui concerne la formation et le développement, il est important de prendre en compte la situation familiale des employés afin d'organiser leur disponibilité pour les formations. Par ailleurs, les informations liées au permis de conduire doivent être gérées si elles sont nécessaires pour la fonction exercée.

Enfin le suivi des relations sociales et l'égalité professionnelle passent par un contrôle rigoureux visant à éviter toute forme de discrimination par exemple en fonction du sexe ou de la nationalité Il est également essentiel de mettre en place des politiques RH qui respectent la diversité et favorisent l'inclusion.

IV. Principe d'une Durée Limitée de Conservation des Données

Les informations ne peuvent être conservées de façon indéfinie. Une durée de conservation précise doit être déterminée en fonction de la finalité de chaque fichier.

Actions Concrètes : Déterminez et appliquez les durées de conservation des données (délais prévus pour l'effacement):

Traitement	Base Active (Durée de présence)	Archivage Intermédiaire
Bulletin de salaire	1 mois	5 ans
Registre unique du personnel	La durée pendant laquelle le salarié fait partie des effectifs	5 ans à compter du départ du salarié
Gestion de la carrière	Le temps de la présence du salarié.	Le temps des règles de prescription (ex : 5 ans).
Coordonnées des personnes à prévenir en cas d'urgence	Le temps de la présence du salarié.	Jusqu'au départ du salarié.

V. Obligations d'Information et de Sécurité

A) Information des Personnes (Transparence)

Les personnes concernées doivent être informées de l'existence du traitement, de ses caractéristiques et des droits dont elles disposent.

Action Concrète : Fournissez une information écrite à tous les employés.

- Cette information doit préciser les finalités , les bases légales et la durée de conservation pour chaque traitement (ex: gestion administrative, suivi de carrière).
- Elle doit lister les droits des personnes, notamment le droit d'accès, de rectification et d'opposition.

B) Sécurité, Intégrité et Confidentialité

L'employeur est astreint à une obligation de sécurité et doit prendre toutes les précautions utiles au regard des risques pour préserver la sécurité des données.

Actions Concrètes : Mettez en œuvre les mesures suivantes (extrait des mesures de sécurité du référentiel) :

Catégories	Mesures
Authentifier les utilisateurs	Définir un identifiant (login) unique à chaque utilisateur. Adopter une politique de mot de passe utilisateur.
Gérer les habilitations	Limitier l'accès aux données personnelles aux seules personnes habilitées à y accéder en raison de leurs fonctions. Définir des profils d'habilitation et supprimer les permissions d'accès obsolètes.
Tracer les accès	Prévoir un système de journalisation.
Sécuriser les postes de travail	Prévoir une procédure de verrouillage automatique de session au-delà d'une courte période. Utiliser des antivirus régulièrement mis à jour.
Sauvegarder	Effectuer des sauvegardes régulières et les stocker dans un endroit sûr.
Encadrer la destruction des données	Effacer les données de tout matériel avant sa mise au rebut.

VI. Analyse d'Impact relative à la Protection des Données (AIPD)

Le traitement mis en œuvre dans les conditions du référentiel pour la seule gestion du personnel des organismes qui emploient moins de 250 personnes est listé comme ne nécessitant pas une analyse d'impact.

Action Concrète :

- Puisque l'entreprise emploie une centaine de salariés et que le traitement concerne uniquement la gestion du personnel , l'AIPD n'est a priori pas requise.
- Toutefois, si l'entreprise envisage d'introduire un profilage des employés (ex: traitement visant à détecter les départs de salariés grâce à un algorithme) ou un système de surveillance systématique , une AIPD devient obligatoire.

L'implémentation rapide et documentée de ces préconisations assurera la conformité de votre entreprise et évitera des sanctions administratives dissuasives.

VII. Synthèse et Plan d'Action Immédiat

Synthèse Exécutive

L'état actuel des traitements de données au service des Ressources Humaines expose la société à un risque de non-conformité élevé. Nous avons constaté la conservation de données excessives et le traitement non encadré de données sensibles. La non-conformité aux principes de base du traitement peut entraîner de lourdes sanctions administratives (jusqu'à 4 % du chiffre d'affaires annuel mondial) et pénales.

La mise en conformité est une urgence qui nécessite une action immédiate pour garantir la protection des données à caractère personnel.

Plan d'Action

Les dirigeants doivent valider et lancer sans délai les quatre actions clés suivantes pour sécuriser les traitements et démontrer la conformité de l'entreprise :

1. **Gouvernance** : Désigner un Délégué à la Protection des Données (DPD) pour orchestrer la démarche de conformité et être le point de contact avec l'autorité de contrôle.
2. **Documentation** : Créer le Registre des activités de traitement, car il est obligatoire pour les entreprises de moins de 250 salariés gérant des traitements non occasionnels (comme la paie) et des données sensibles.
3. **Minimisation** : Procéder à un nettoyage immédiat des bases pour supprimer les données non pertinentes et illicites (exemples : Nature des études des enfants, Profession des parents, Indications de pathologies, Nombre de jours de grève).
4. **Transparence** : Informer tous les employés par écrit (l'information écrite est privilégiée) sur les finalités, les bases légales et les droits dont ils disposent (d'opposition, accès, rectification, etc.).

Fait à Niort, le 17/10/2025